Middle Mayhem – SOC Investigation

Executive Summary

This investigation documents a full attack life cycle involving reconnaissance, exploitation of a Next.js vulnerability (CVE-2025-29927), remote code execution, and lateral movement.

The attacker successfully bypassed authentication using a crafted middleware header, deployed a reverse shell, and gained access to an internal account.

This report demonstrates practical SOC investigation skills including log analysis, attack chain reconstruction, and detection engineering.

Attack Timeline

1. Reconnaissance: High-volume URI scanning from 218.92.0.204

2. Discovery: robots.txt revealed /admin and /admin/file-upload

3. Exploitation: x-middleware-subrequest header used for auth bypass

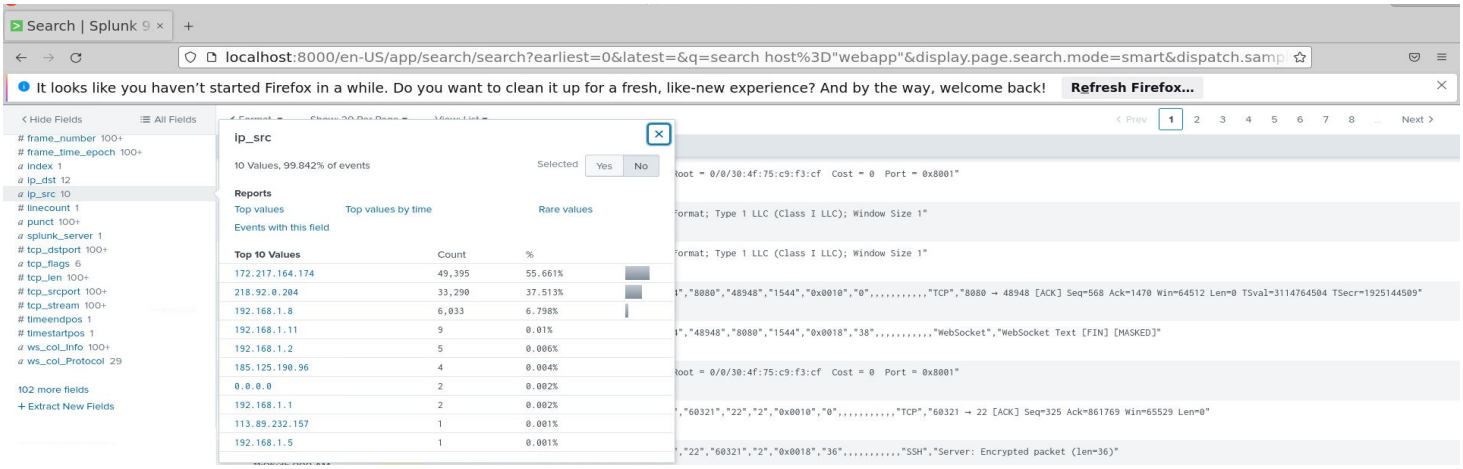
4. Execution: Reverse shell uploaded via /api/upload

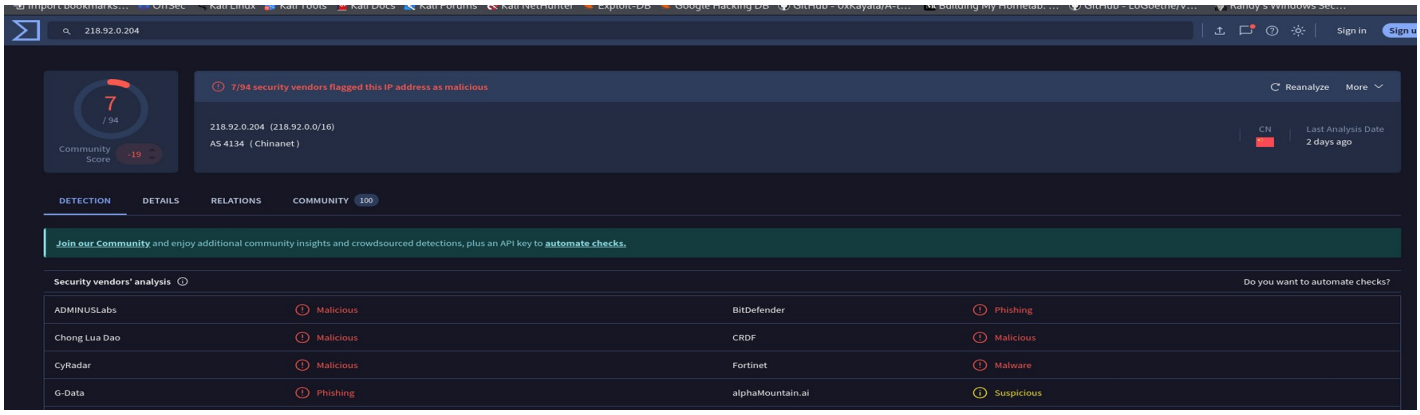
5. C2: Callback to 113.89.232.157:31337

6. Lateral Movement: SSH brute-force attempts

7. Compromise: Successful login as dbserve

1. Reconnaissance Detection





Observation:

Large volume of requests from single IP 218.92.0.204 (flagged malicious by VirusTotal).

Analysis:

Indicates automated scanning rather than normal user behavior.

2. Enumeration & Discovery

Observation:

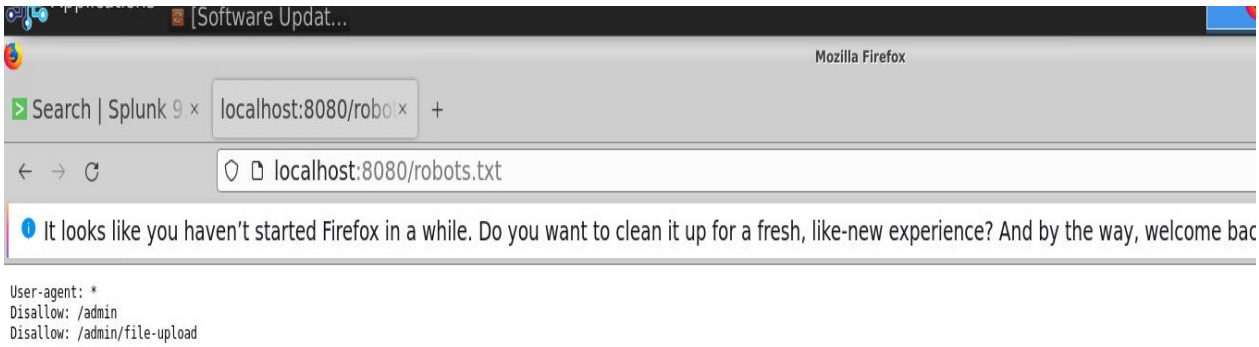
9930 URI requests from malicious IP 218.92.0.204.

Analysis:

Indicates automated scanning rather than normal user behavior.

Insight:

High URI diversity (9930 unique endpoints) strongly suggests directory brute-forcing tools.



Observation:

robots.txt reveals /admin and /admin/file-upload.

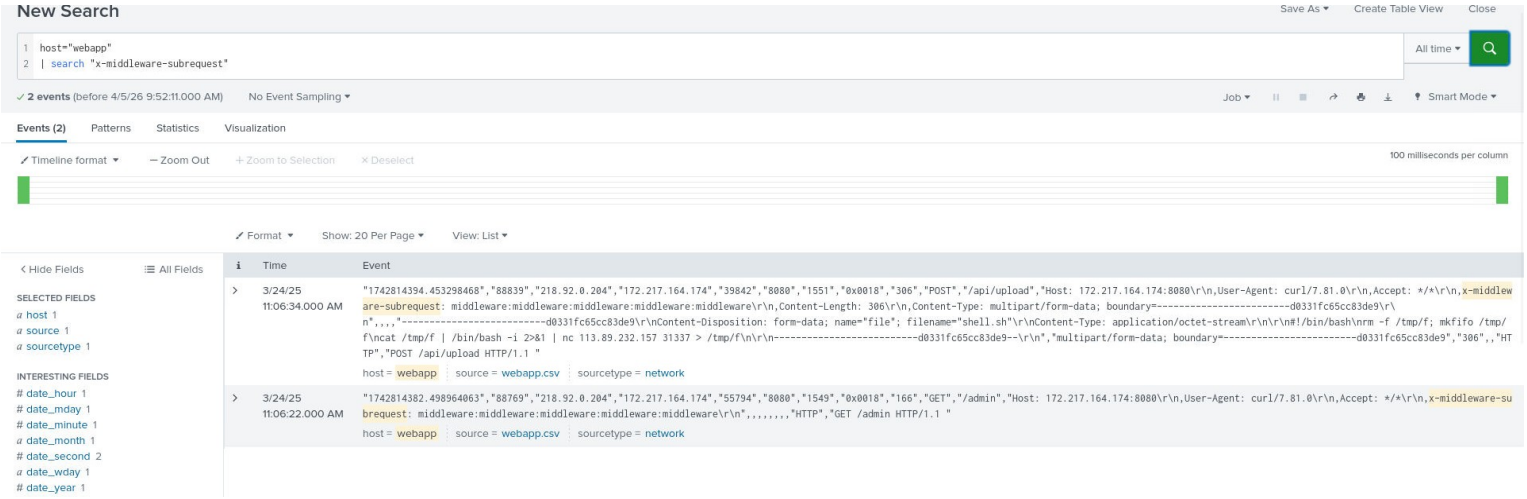
Analysis:

Attacker used this to shortcut discovery and target sensitive endpoints.

Insight:

robots.txt should not expose sensitive paths without access control enforcement.

3. Exploitation



Observation:

Presence of x-middleware-subrequest header.

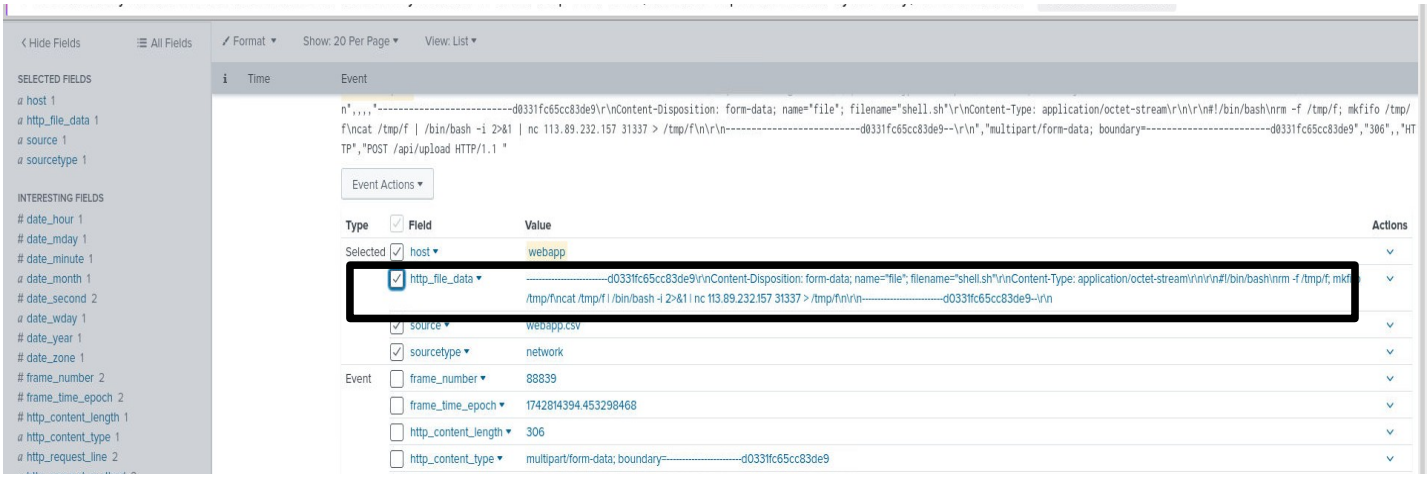
Analysis:

Indicates exploitation of CVE-2025-29927 for authentication bypass.

Insight:

Internal-use headers appearing in external traffic are strong indicators of exploitation attempts.

4. Remote Code Execution



Observation:

Access to /api/upload endpoint. File shell.sh initiates connection to 113.89.232.157:31337.

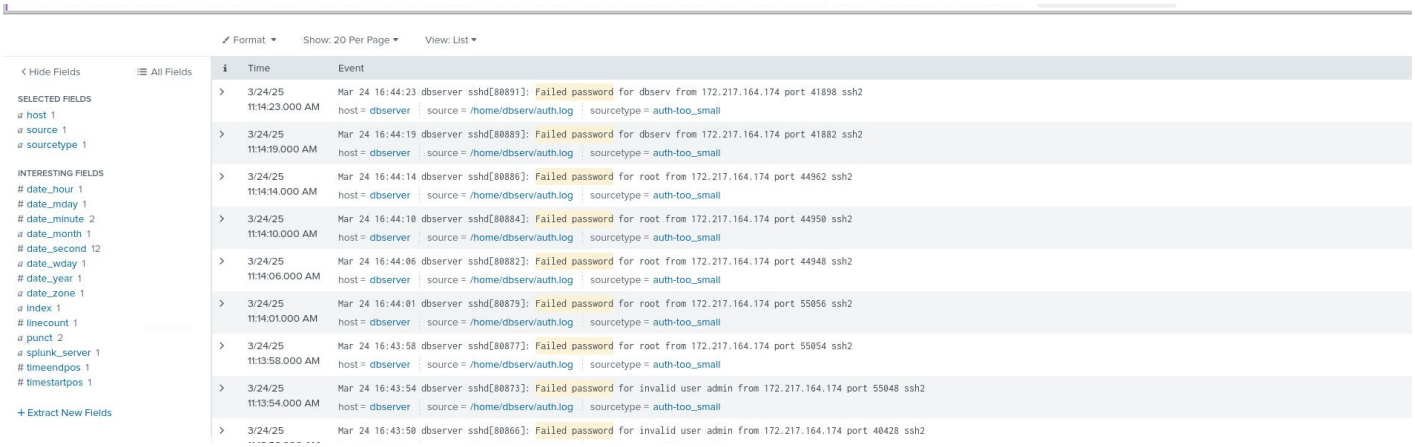
Analysis:

File upload used to deploy reverse shell. Confirms remote command execution capability.

Insight:

Outbound connections to uncommon ports are strong indicators of compromise.

5. Lateral Movement

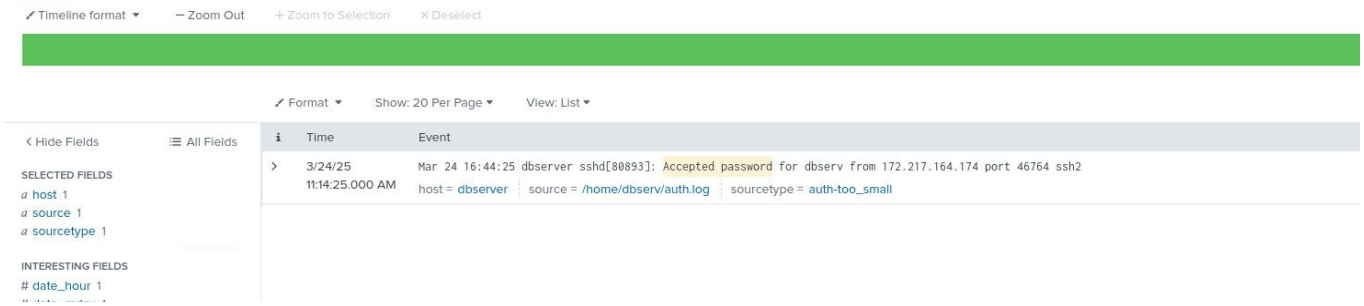


Observation:

Multiple failed SSH login attempts at regular time intervals for user dbserve.

Analysis:

Indicates brute-force activity.



Observation:

Login success for user dbserve.

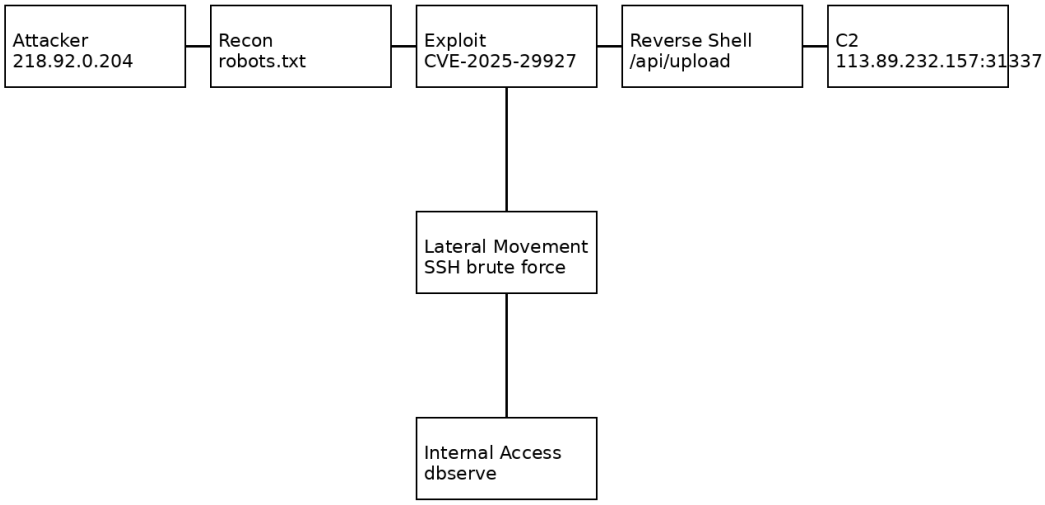
Analysis:

Confirms lateral movement and credential compromise.

Insight:

Transition from web exploitation to SSH access shows attacker progression beyond initial foothold.

6. Attack Flow



7. Conclusion

The attack highlights weaknesses in application security, monitoring, and access control, emphasizing the need for layered defenses.